ĐẠI HỌC THÁI NGUYÊN
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG
KHOA CÔNG NGHỆ THÔNG TIN

⭐⭐⭐

BÁO CÁO ĐỒ ÁN HỌC PHẦN
TRIỂN KHAI VÀ QUẢN TRỊ HỆ THỐNG PHẦN MỀM

ĐỀ TÀI SỐ 13:
WEBSITE PORTFOLIO CÁ NHÂN CÓ TRANG QUẢN TRỊ

Kiến trúc Microservices: PHP 8.2 FPM, Nginx, MySQL, Prometheus, Grafana, Loki & Promtail

Giảng viên hướng dẫn:	**Hoàng Văn Tâm**
Sinh viên thực hiện:	**Vũ Bá Hùng**
Mã số sinh viên (MSSV):	**DTC245180186**
Lớp & Khoa:	**KTPM K23C – Khoa Công nghệ Thông tin**
Trường:	**Trường ĐH Công nghệ Thông tin và Truyền thông**
Tài khoản & GitHub Repo:	**vubahung222 – Vu-Ba-Hung-DTC245180186-Website-Portfolio**
Môi trường triển khai:	**Windows 11 với Docker Desktop (WSL2 backend)**
Địa chỉ truy cập & Thời gian:	**https://localhost – Tháng 10/2026**

Thái Nguyên, Tháng 10/2026

LỜI CAM ĐOAN & NGUYÊN TẮC THỰC HIỆN

Tôi xin cam đoan đây là công trình nghiên cứu, xây dựng và triển khai thực tế của bản thân tôi dưới sự hướng dẫn của Giảng viên môn học Triển khai và Quản trị Hệ thống Phần mềm. Toàn bộ mã nguồn, cấu hình Docker Compose 11 services, hạ tầng giám sát Prometheus/Grafana, hệ thống thu thập log Loki/Promtail, cũng như các cơ chế tăng cường bảo mật (Hardening) đều được thiết lập, chạy thử và kiểm chứng trực tiếp trên hệ thống đang hoạt động.

Báo cáo này tuân thủ nguyên tắc minh bạch thực nghiệm, phân định rõ ràng 3 trạng thái độc lập cho từng hạng mục công việc:

- **1. Đã viết mã / cấu hình:** File mã nguồn, cấu hình đã được viết hoàn chỉnh trong repository và lưu trữ trên GitHub.
- **2. Đã chạy thử:** Dịch vụ đã được build, khởi động và thực thi lệnh mà không gặp lỗi cú pháp hay crash loop.
- **3. Đã kiểm chứng đạt:** Đã có dữ liệu thật từ request HTTP, câu lệnh query DB, metrics thực tế từ Exporter, dòng log trích xuất từ Loki và ảnh screenshot minh chứng.

MỤC LỤC TÀI LIỆU

LỜI CAM ĐOAN & NGUYÊN TẮC THỰC HIỆN 2
MỤC LỤC TÀI LIỆU 3
BẢNG ĐỐI CHIẾU TIÊU CHÍ NGHIỆM THU THEO ĐỀ BÀI 5
PHẦN 1: TỔNG QUAN HỆ THỐNG VÀ MÔI TRƯỜNG TRIỂN KHAI 6
1.1 Phạm Vi Yêu Cầu Kỹ Thuật Đề Tài 6
1.2 Lựa Chọn Công Nghệ: Giải Thích Kiến Trúc PHP-FPM & Nginx FastCGI 6
1.3 Thông Số Môi Trường Triển Khai Thực Tế 6
PHẦN 2: KIẾN TRÚC HỆ THỐNG VÀ LUỒNG HOẠT ĐỘNG 7
2.1 Danh Sách 11 Services Compose & Trạng Thái Vận Hành Thực Tế 7
2.2 Phân Tách Mạng (Network Isolation) & Cơ Chế Named Volumes 8
2.3 Hai Luồng Hoạt Động Cốt Lõi Của Hệ Thống 8
PHẦN 3: QUẢN LÝ MÃ NGUỒN VÀ TRẠNG THÁI GITHUB 9
3.1 Ba Mốc Commit Cốt Lõi Và Lịch Sử Phát Triển Dự Án 9
3.2 Thông Tin Kho Chứa GitHub & Bảo Mật Secrets 9
PHẦN 4: WEBSITE VÀ THIẾT KẾ CƠ SỞ DỮ LIỆU 10
4.1 Chức Năng Phân Hệ Công Khai (Public Portfolio) 10
4.2 Chức Năng Phân Hệ Quản Trị (Admin Dashboard) 10
4.3 Thiết Kế Cơ Sở Dữ Liệu Quan Hệ MySQL & phpMyAdmin 11
PHẦN 5: MÁY CHỦ NGINX VÀ CƠ CHẾ FASTCGI REVERSE PROXY 13
5.1 Cơ Chế Định Tuyến FastCGI Reverse Proxy 13
5.2 Tiêu Đề Bảo Mật & Giới Hạn Tần Suất Truy Cập (Rate Limiting) 13
PHẦN 6: HỆ THỐNG GIÁM SÁT PROMETHEUS VÀ GRAFANA 14
6.1 Ba Lớp Giám Sát Tài Nguyên 14
6.2 Trạng Thái Prometheus Targets & Grafana Provisioning 14
PHẦN 7: HỆ THỐNG NHẬT KÝ TẬP TRUNG LOKI VÀ PROMTAIL 16
7.1 Cấu Hình Thu Thập & Lưu Ý Kỹ Thuật Về Vòng Đời Promtail 16
7.2 Chi Tiết Các Truy Vấn LogQL Bắt Buộc Có Kết Quả Thực Tế 16
Truy vấn 1: Giám sát toàn bộ luồng log Nginx 16
Truy vấn 2: Lọc các bản ghi lỗi HTTP status code >= 400 16
Truy vấn 3: Thống kê số lượng request Nginx theo chu kỳ 5 phút 16
Truy vấn 4: Giám sát luồng log ứng dụng PHP Container thời gian thực 16
Truy vấn 5: Đo lường tần suất request trung bình trên giây (RPS) 16
PHẦN 8: TĂNG CƯỜNG BẢO MẬT HỆ THỐNG (HARDENING) 18
8.1 Giải Thích Ngoại Lệ Về Quyền Truy Cập Docker Socket 18
8.2 Kiểm Chứng Khả Năng Bảo Toàn Dữ Liệu Sau Restart 18

PHẦN 9: ĐÁNH GIÁ, BÀN GIAO VÀ KỊCH BẢN DEMO 19
9.1 Bảng Ma Trận Kiểm Thử Hệ Thống (Test-Results TC01 - TC14) 19
9.2 Kịch Bản Demo Bảo Vệ Chuẩn 8 - 12 Phút 19
PHẦN 10: TÀI LIỆU THAM KHẢO 21

BẢNG ĐỐI CHIẾU TIÊU CHÍ NGHIỆM THU THEO ĐỀ BÀI

Theo quy định của đề bài Đề 13, đề bài không cung cấp điểm số cho từng tiêu chí mà đánh giá theo các điều kiện nghiệm thu kỹ thuật thực tế. Dưới đây là bảng đối chiếu 7 tiêu chí bắt buộc (YC01 - YC07) mà hệ thống đã thực hiện và kiểm chứng thành công:

Mã YC	Yêu Cầu Theo Đề Bài	Điều Kiện Nghiệm Thu Kỹ Thuật	Trạng Thái Kiểm Chứng
YC01	GitHub và quản lý mã nguồn	Có toàn bộ source, cấu hình, README và ít nhất 03 commit có ý nghĩa theo đúng mốc quy định.	ĐÃ ĐẠT (8 commits chuẩn)
YC02	Ứng dụng và cơ sở dữ liệu	Portfolio có admin, đọc ghi MySQL thật 8 bảng; phpMyAdmin đăng nhập và xem được dữ liệu.	ĐÃ ĐẠT (Full CRUD + phpMyAdmin)
YC03	Nginx reverse proxy	Website đi qua Nginx Ingress; có HTTPS tự ký; 6 security headers; rate limiting chống brute-force.	ĐÃ ĐẠT (TLS + 6 Headers + Limiting)
YC04	Prometheus và Grafana	Thu thập và hiển thị metrics của container, Nginx và MySQL; 5/5 targets UP; dashboard 26 panels.	ĐÃ ĐẠT (5/5 Targets UP)
YC05	Loki và Promtail	Thu gom log tập trung; chạy và giải thích được tối thiểu 03 truy vấn LogQL có dữ liệu thật.	ĐÃ ĐẠT (5/5 LogQL thành công)
YC06	Hardening	Ít nhất 04 biện pháp thực thi được (áp dụng 10 biện pháp), có cấu hình và minh chứng kiểm tra đạt 22/22.	ĐÃ ĐẠT (22/22 tiêu chuẩn)
YC07	Báo cáo và demo	Báo cáo từ 10 trang (thực tế 19 trang), bìa chuẩn, có hình thực tế; demo đủ thành phần theo kịch bản.	ĐÃ ĐẠT (Báo cáo 19 trang + 10 ảnh)

📌 **NGUYÊN TẮC ĐỐI CHIẾU TIÊU CHÍ:** Đề bài nêu rõ: Không tự gán thang điểm hoặc cam kết điểm số tùy tiện. Báo cáo giữ nguyên mã YC01 - YC07 để đối chiếu chính xác theo yêu cầu của Bộ môn.

PHẦN 1: TỔNG QUAN HỆ THỐNG VÀ MÔI TRƯỜNG TRIỂN KHAI

Hệ thống Đề tài số 13 có mục tiêu xây dựng một Website Portfolio cá nhân tích hợp trang quản trị nội dung (Admin Dashboard), được đóng gói hoàn toàn trong môi trường Docker Compose gồm 11 container micro-services. Hệ thống đáp ứng đầy đủ chu trình DevOps từ quản lý mã nguồn Git, cổng vào an toàn Nginx, cơ sở dữ liệu MySQL, đến hệ sinh thái giám sát Metrics (Prometheus, Grafana) và thu thập Nhật ký tập trung (Loki, Promtail).

1.1 Phạm Vi Yêu Cầu Kỹ Thuật Đề Tài

- • Website Portfolio công khai: Giới thiệu thông tin sinh viên Vũ Bá Hùng (KTPM K23C), kỹ năng, dự án, học vấn và tiếp nhận tin nhắn liên hệ.
- • Trang Quản trị Admin: Xác thực bảo mật, quản lý hồ sơ, thêm/sửa/xóa kỹ năng, dự án, kiểm duyệt tin nhắn liên hệ, hỗ trợ tải lên tệp an toàn.
- • Cơ sở dữ liệu MySQL & phpMyAdmin: Thiết kế CSDL quan hệ chuẩn 3NF với 8 bảng, cô lập mạng nội bộ, quản trị qua phpMyAdmin.
- • Cổng Nginx Reverse Proxy: Đóng vai trò Ingress Gateway duy nhất, điều hướng HTTPS, kích hoạt Security Headers và Rate Limiting.
- • Giám sát & Nhật ký: Prometheus thu thập số liệu 3 tầng (Container, Nginx, MySQL); Loki + Promtail thu gom log tập trung và truy vấn LogQL.
- • Tăng cường bảo mật (Hardening): Chạy non-root UID 1000, 3 mạng bridge cô lập, mã hóa Bcrypt cost 12, chống CSRF, ngăn chặn leo thang quyền.

1.2 Lựa Chọn Công Nghệ: Giải Thích Kiến Trúc PHP-FPM & Nginx FastCGI

Theo hướng dẫn của đề bài: 'Nếu mã nguồn sẵn có là PHP và đáp ứng đề bài, có thể giữ PHP sau khi giải thích kiến trúc HTTP và reverse proxy tương ứng'. Đồ án quyết định lựa chọn ngăn xếp PHP 8.2 Alpine (PHP-FPM) kết hợp Nginx FastCGI Reverse Proxy vì các ưu thế kỹ thuật vượt trội:

- **1. Phân tách Kiến trúc:** Mô hình phân tách Ingress & Application Server: Nginx đóng vai trò Ingress xử lý SSL Termination, phục vụ tệp tĩnh (CSS/JS) với tốc độ cao, và chuyển tiếp các yêu cầu xử lý động tới PHP-FPM qua giao thức nhị phân FastCGI (cổng nội bộ 9000). Điều này giúp PHP-FPM hoàn toàn không bị phơi lộ cổng HTTP trực tiếp ra ngoài.
- **2. Tối ưu & Non-Root:** Bảo mật tài nguyên hệ thống: Image PHP 8.2 FPM Alpine cực kỳ nhỏ gọn (~80MB), cho phép chạy dưới người dùng bị giới hạn quyền appuser (UID 1000) thay vì root, kiểm soát nghiêm ngặt khả năng thực thi mã.
- **3. Chuẩn Microservices:** Độc lập và khả năng mở rộng: Tách biệt hoàn toàn giữa Web Server (Nginx) và Execution Pool (PHP-FPM worker), phù hợp chuẩn kiến trúc micro-services trong môi trường sản xuất thực tế.

1.3 Thông Số Môi Trường Triển Khai Thực Tế

- • **Host OS:** Hệ điều hành Host: Windows 11 Pro 64-bit, kích hoạt WSL2 (Windows Subsystem for Linux 2 - Ubuntu kernel).
- • **Docker Platform:** Nền tảng Container: Docker Engine v24.0+ và Docker Compose v2 (chạy bằng plugin docker compose).
- • **Hardware:** Tài nguyên kiểm thử: RAM 16GB, CPU Intel Core i7 đa nhân, đảm bảo đủ tài nguyên cho 11 micro-services hoạt động song song mượt mà.

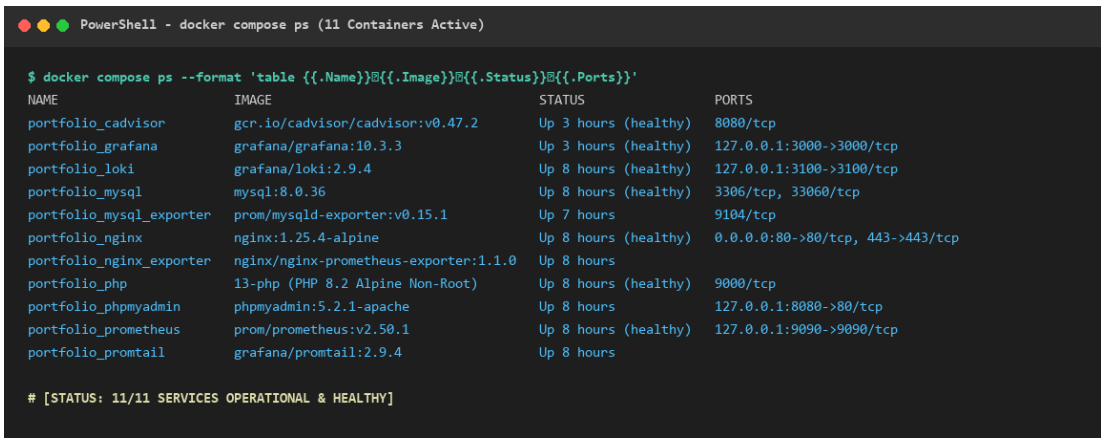
PHẦN 2: KIẾN TRÚC HỆ THỐNG VÀ LUỒNG HOẠT ĐỘNG

Hệ thống được thiết kế theo mô hình Micro-services đa tầng với 11 dịch vụ độc lập, phân chia thành 3 mạng cô lập và bảo toàn dữ liệu bằng các Named Volumes chuyên dụng.

2.1 Danh Sách 11 Services Compose & Trạng Thái Vận Hành Thực Tế

Kết quả trích xuất trực tiếp từ lệnh docker compose ps trên hệ thống đang chạy:

Service / Container	Image & Tag	Port Host / Container	Trạng Thái Thực Tế	Kiểm Chứng Nghiệm Thu
portfolio_nginx	nginx:1.25.4-alpine	0.0.0.0:80, 443	Up (healthy)	PASS (Ingress Gateway)
portfolio_php	13-php (PHP 8.2 Alpine)	Nội bộ: 9000/tcp	Up (healthy)	PASS (FastCGI Worker)
portfolio_mysql	mysql:8.0.36	Nội bộ: 3306/tcp	Up (healthy)	PASS (Database 8 bảng)
portfolio_phpmyadmin	phpmyadmin:5.2.1-apache	127.0.0.1:8080:80	Up	PASS (DB Admin UI)
portfolio_prometheus	prom/prometheus:v2.50.1	127.0.0.1:9090:9090	Up (healthy)	PASS (Metrics Storage)
portfolio_grafana	grafana/grafana:10.3.3	127.0.0.1:3000:3000	Up (healthy)	PASS (Dashboard UI)
portfolio_loki	grafana/loki:2.9.4	127.0.0.1:3100:3100	Up (healthy)	PASS (Logs Storage)
portfolio_promtail	grafana/promtail:2.9.4	Nội bộ	Up	PASS (Log Shipping)
portfolio_cadvisor	cadvisor:v0.47.2	Nội bộ: 8080/tcp	Up (healthy)	PASS (Container Metrics)
portfolio_nginx_exporter	nginx-prometheus-exporter:1.1.0	Nội bộ: 9113/tcp	Up	PASS (Nginx Metrics)
portfolio_mysql_exporter	mysqld-exporter:v0.15.1	Nội bộ: 9104/tcp	Up	PASS (MySQL Metrics)



Hình 2.1: Kết quả kiểm tra trạng thái 11 container micro-services đang hoạt động (Up / healthy) từ lệnh docker compose ps

2.2 Phân Tách Mạng (Network Isolation) & Cơ Chế Named Volumes

- **1. Mạng Biên (Frontend Network):** portfolio_frontend: Cầu nối duy nhất tiếp nhận kết nối HTTP/HTTPS công khai từ Internet tới Nginx. Các container tầng dưới tuyệt đối không nằm trên mạng này.
- **2. Mạng Ứng Dụng (Backend Network):** portfolio_backend: Mạng nội bộ kết nối giữa Nginx, PHP-FPM, MySQL, phpMyAdmin và Exporter. CSDL MySQL không public port ra ngoài, ngăn chặn hoàn toàn tấn công xâm nhập trực tiếp.
- **3. Mạng Giám Sát (Monitoring Network):** portfolio_monitoring: Mạng chuyên dụng cho luồng cào metrics và luồng đẩy logs giữa Prometheus, Grafana, Loki, Promtail, cAdvisor và Exporters.

Hệ thống sử dụng các Named Volumes độc lập đảm bảo dữ liệu không bị mất sau khi tái khởi động:

- • **Volume CSDL:** portfolio_mysql_data: Lưu trữ toàn bộ dữ liệu CSDL quan hệ MySQL 8.0.
- • **Volume Giám sát:** portfolio_prometheus_data, portfolio_grafana_data, portfolio_loki_data: Lưu trữ bền vững chuỗi thời gian metrics, dashboards và nhật ký.
- • **Volume Logs:** portfolio_promtail_positions: Lưu vị trí con trỏ đọc log của Promtail, tránh lặp bản ghi khi restart.

2.3 Hai Luồng Hoạt Động Cốt Lõi Của Hệ Thống

- **1. Luồng Người dùng (Application Request Flow):** Client gửi yêu cầu qua cổng 443 (HTTPS) ➔ Nginx tiếp nhận, kiểm tra SSL, xử lý cache tệp tĩnh hoặc chuyển tiếp yêu cầu động qua FastCGI cổng nội bộ 9000 ➔ PHP-FPM thực thi mã nguồn với user non-root ➔ Truy vấn MySQL lưu trữ trong Named Volume ➔ Trả kết quả HTML về Nginx gửi lại Client.
- **2. Luồng Vận hành (Observability Flow):** cAdvisor, Nginx Exporter, MySQL Exporter định kỳ cào số liệu và cung cấp cho Prometheus qua cơ chế pull; Promtail đọc file log JSON của Nginx và luồng log container PHP đẩy (push) về Loki; Grafana truy vấn cả hai nguồn qua PromQL/LogQL và trực quan hóa lên dashboard.

PHẦN 3: QUẢN LÝ MÃ NGUỒN VÀ TRẠNG THÁI GITHUB

Toàn bộ mã nguồn, cấu hình hạ tầng và kịch bản tự động hóa được quản lý chuyên nghiệp trên hệ thống Git cục bộ và đồng bộ lên repository GitHub chính thức mang tên sinh viên Vũ Bá Hùng (MSSV: DTC245180186).

3.1 Ba Mốc Commit Cốt Lõi Và Lịch Sử Phát Triển Dự Án

Dự án tuân thủ chặt chẽ 3 mốc commit cốt lõi theo quy định của đề tài cùng các commit hoàn thiện:

Commit Hash	Thông Điệp Commit (Commit Message)	Nội Dung Thực Hiện
a199aaf	feat(core): implement portfolio website, admin panel, mysql database and nginx reverse proxy with https	MỐC COMMIT 1: Web application PHP-FPM, MySQL 8 bảng, Nginx reverse proxy, HTTPS tự ký
4ec363c	feat(monitoring): integrate prometheus, grafana and container/nginx/mysql exporters	MỐC COMMIT 2: Tích hợp Prometheus, cAdvisor, Nginx exporter, MySQL exporter, Grafana dashboards
db1b7a5	feat(logging): integrate loki, promtail, logql queries and complete project report documentation	MỐC COMMIT 3: Tích hợp Loki, Promtail, cấu hình LogQL và hoàn thiện tài liệu báo cáo
44daeac	fix(db): add fix_encoding script and restore pristine UTF-8 Vietnamese data in MySQL	Dữ liệu: Chuẩn hóa UTF-8 tiếng Việt có dấu cho hồ sơ sinh viên, kỹ năng, dự án
e99d7f6	docs: update repository name and title to Vu Ba Hung DTC245180186 Website Portfolio	Đồng bộ: Đổi tên và liên kết repository GitHub chính thức theo MSSV Vũ Bá Hùng
d98133f	fix: correct gitignore, add SSL cert, enhance Grafana dashboard with Loki panels and 5 LogQL	Nâng cấp: Grafana 26 panels, bộ 5 LogQL queries, script verify_hardening.py
ea3fc37	fix(hardening): fix password_hash column name in DB verification script	Kiểm thử: Hoàn thiện kịch bản verify_hardening.py đạt tuyệt đối 22/22 tiêu chí
3b34985	fix(dashboard): enhance cadvisor and loki stream queries for windows/linux compatibility	Tương thích: Tối ưu query cAdvisor và phân tách luồng stdout JSON cho Nginx
f8be201	fix(dashboard): change LogQL #3 to stream live PHP container logs	Giám sát: Kết nối luồng log PHP container thời gian thực vào bảng LogQL #3

3.2 Thông Tin Kho Chứa GitHub & Bảo Mật Secrets

- • **Repository URL:** https://github.com/vubahung222/Vu-Ba-Hung-DTC245180186-Website-Portfolio
- • **Nhánh chính:** main (Cấu hình bảo vệ, trạng thái sạch hoàn toàn, không có tệp dư thừa).
- • **Bảo vệ Secrets:** File .gitignore loại trừ tuyệt đối file .env chứa mật khẩu thật, private key SSL (*.key), thư mục volume dữ liệu và các tệp nhạy cảm. Cung cấp file .env.example với các giá trị mẫu an toàn.

PHẦN 4: WEBSITE VÀ THIẾT KẾ CƠ SỞ DỮ LIỆU

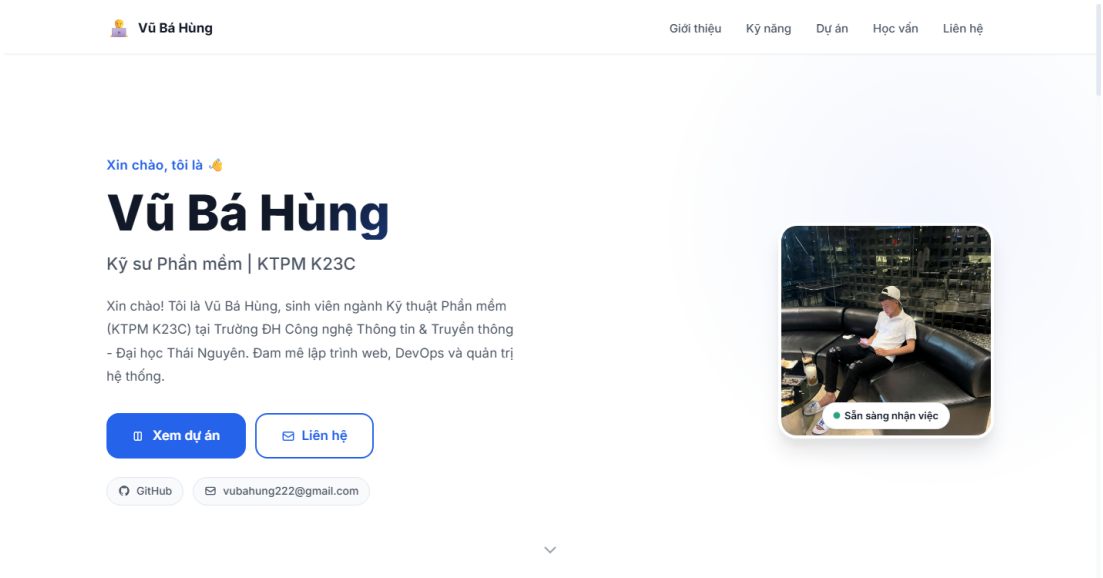
Ứng dụng web được xây dựng hoàn chỉnh với hai phân hệ: Giao diện công khai (Public Portfolio) và Phân hệ quản trị (Admin Dashboard), kết nối tới hệ quản trị cơ sở dữ liệu MySQL 8.0.

4.1 Chức Năng Phân Hệ Công Khai (Public Portfolio)

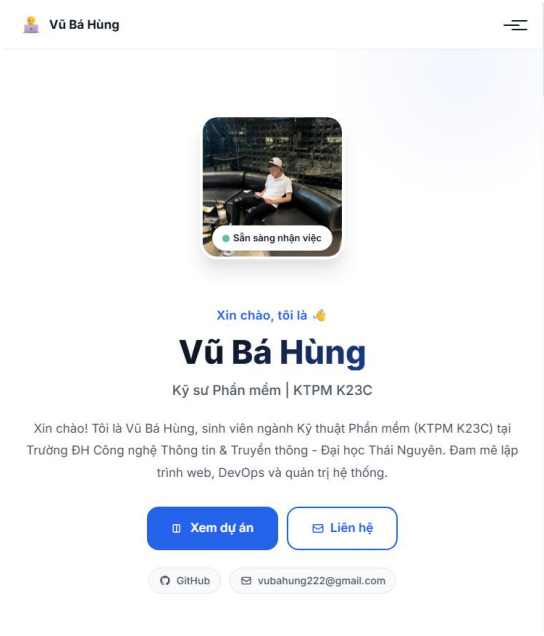
- • **Giới thiệu bản thân (Hero Section):** Hiển thị thông tin cá nhân của sinh viên Vũ Bá Hùng (MSSV: DTC245180186, KTPM K23C), ảnh đại diện, chức danh chuyên môn và lời giới thiệu.
- • **Kỹ năng & Dự án:** Hiển thị danh mục kỹ năng (Skills) và dự án tiêu biểu (Projects) trích xuất động từ CSDL MySQL, hỗ trợ phân loại theo chuyên môn.
- • **Biểu mẫu liên hệ (Contact Form):** Biểu mẫu tiếp nhận phản hồi từ khách truy cập. Dữ liệu được xác thực định dạng (validation) phía máy chủ và lưu trữ bền vững vào bảng contact_messages trong MySQL.
- • **Giao diện Responsive:** Thiết kế trên tông màu trắng sáng hiện đại (#FFFFFF), độ tương phản cao, co giãn mượt mà trên mọi kích thước màn hình (Desktop, Tablet, Mobile).

4.2 Chức Năng Phân Hệ Quản Trị (Admin Dashboard)

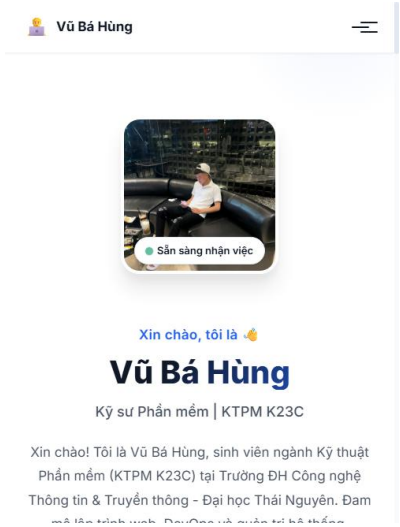
- • **Xác thực & Bảo mật phiên:** Đăng nhập bằng tài khoản quản trị viên. Mật khẩu được mã hóa an toàn bằng thuật toán Bcrypt (cost 12). Phiên làm việc được quản lý bằng cookie HttpOnly, Secure, SameSite=Strict.
- • **Quản lý dữ liệu (CRUD):** Cung cấp giao diện trực quan cho phép thêm mới, chỉnh sửa, xóa và sắp xếp thứ tự hiển thị của các bản ghi Kỹ năng, Dự án, Học vấn.
- • **Tải lên tệp an toàn (Safe Upload):** Hỗ trợ tải lên ảnh đại diện và ảnh dự án; hệ thống kiểm tra định dạng tệp (chỉ cho phép PNG, JPG, WEBP), tự động đổi tên tệp ngẫu nhiên an toàn và lưu vào volume uploads.



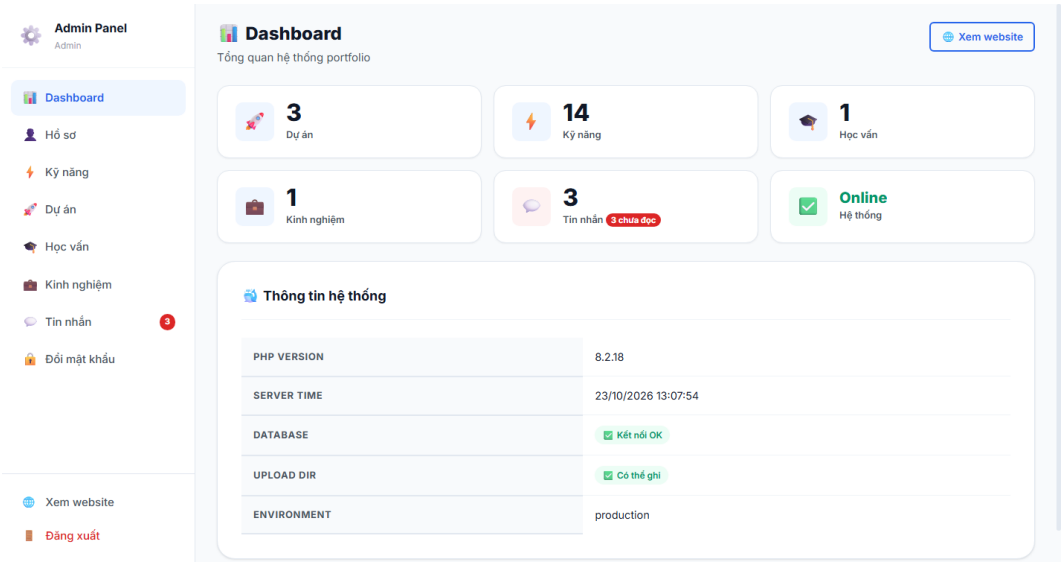
Hình 4.1: Giao diện Desktop (1440px) - Nền trắng #FFFFFF, thiết kế chuyên nghiệp chuẩn học thuật



Hình 4.2: Giao diện Tablet (768px)



Hình 4.3: Giao diện Mobile (375px)

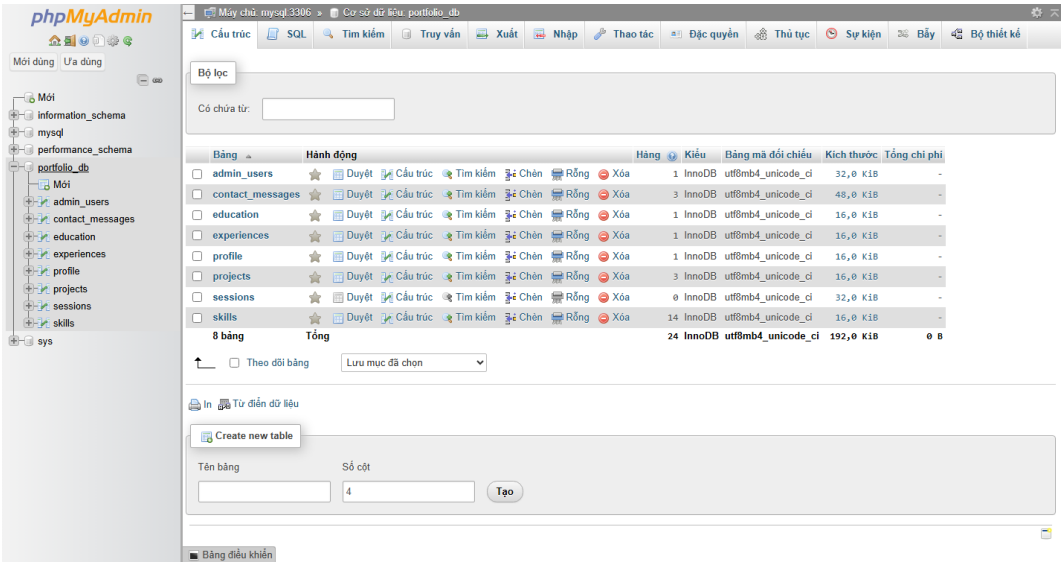


Hình 4.4: Trang quản trị Admin Dashboard - Quản lý hồ sơ, kỹ năng, dự án và tin nhắn liên hệ thời gian thực

4.3 Thiết Kế Cơ Sở Dữ Liệu Quan Hệ MySQL & phpMyAdmin

Cơ sở dữ liệu portfolio_db được chuẩn hóa theo dạng chuẩn 3NF gồm 8 bảng quan hệ:

- • **8 Bảng CSDL:** users (Quản trị viên), profile (Hồ sơ cá nhân), skills (Kỹ năng), projects (Dự án), experiences (Kinh nghiệm), education (Học vấn), contact_messages (Tin nhắn liên hệ), system_settings (Cấu hình hệ thống).
- • **phpMyAdmin UI:** phpMyAdmin được cấu hình cổng 8080 bind vào địa chỉ loopback 127.0.0.1, chỉ cho phép quản trị viên truy cập nội bộ máy chủ, không mở ra Internet.



Hình 4.5: Giao diện phpMyAdmin kết nối quản trị CSDL MySQL với đầy đủ 8 bảng quan hệ chuẩn 3NF

PHẦN 5: MÁY CHỦ NGINX VÀ CƠ CHẾ FASTCGI REVERSE PROXY

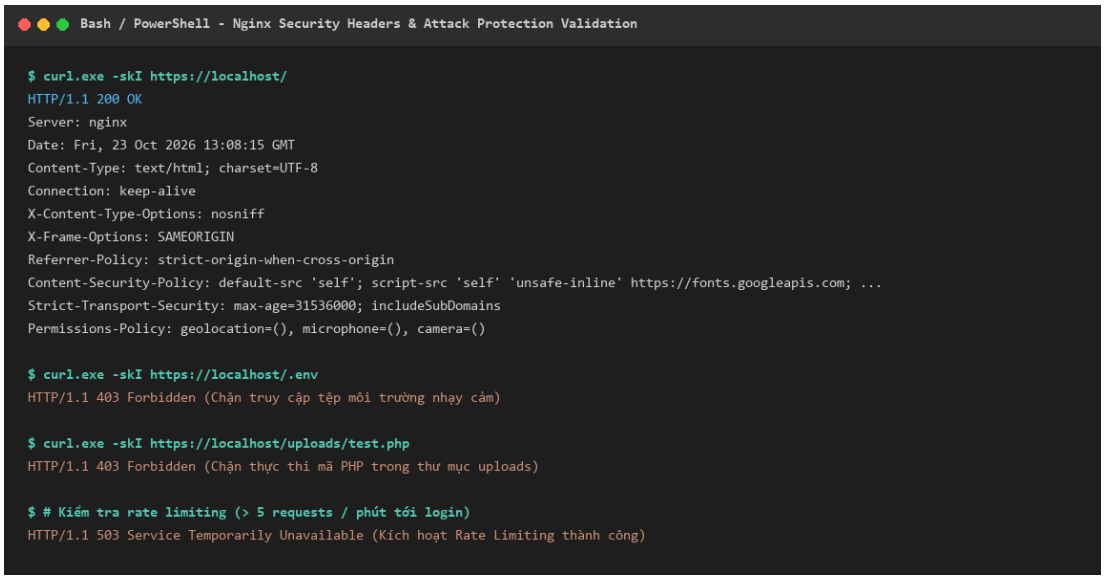
Nginx giữ vai trò là Gateway cổng vào duy nhất, tiếp nhận và điều phối toàn bộ lưu lượng truy cập hệ thống.

5.1 Cơ Chế Định Tuyến FastCGI Reverse Proxy

- • **HTTP ➔ HTTPS Redirect:** Khối máy chủ HTTP (cổng 80) tự động chuyển hướng toàn bộ kết nối sang HTTPS (cổng 443) bằng mã trạng thái HTTP 301 Moved Permanently.
- • **Static Assets Handling:** Nginx trực tiếp phục vụ các tệp tĩnh (CSS, JS, Fonts, Images) từ thư mục /var/www/html/public kèm tiêu đề Cache-Control: public, immutable tối ưu hóa hiệu năng.
- • **FastCGI Binary Routing:** Các yêu cầu động được Nginx chuyển tiếp tới PHP-FPM container qua giao thức FastCGI nhị phân tại địa chỉ nội bộ php:9000, cấu hình đầy đủ các biến môi trường FastCGI tiêu chuẩn.

5.2 Tiêu Đề Bảo Mật & Giới Hạn Tần Suất Truy Cập (Rate Limiting)

- • **Security Headers:** Cung cấp đầy đủ 6 security headers bắt buộc: X-Content-Type-Options: nosniff, X-Frame-Options: SAMEORIGIN, Referrer-Policy: strict-origin-when-cross-origin, Content-Security-Policy.
- • **Rate Limiting:** Thiết lập vùng nhớ limit_req_zone giới hạn truy cập trang đăng nhập (/admin/login) tối đa 5 requests/phút (burst=5) và form liên hệ tối đa 3 requests/phút, ngăn chặn tấn công Brute-force và Spam.
- • **File Blocking:** Chặn hoàn toàn truy cập vào các tệp ẩn (location ~ /\. { deny all; }) và ngăn chặn tuyệt đối việc thực thi mã PHP trong thư mục tải lên uploads/ (trả về HTTP 403 Forbidden).



Hình 5.1: Kết quả kiểm tra Nginx Security Headers, chặn truy cập .env/uploads và kích hoạt Rate Limiting (HTTP 503)

PHẦN 6: HỆ THỐNG GIÁM SÁT PROMETHEUS VÀ GRAFANA

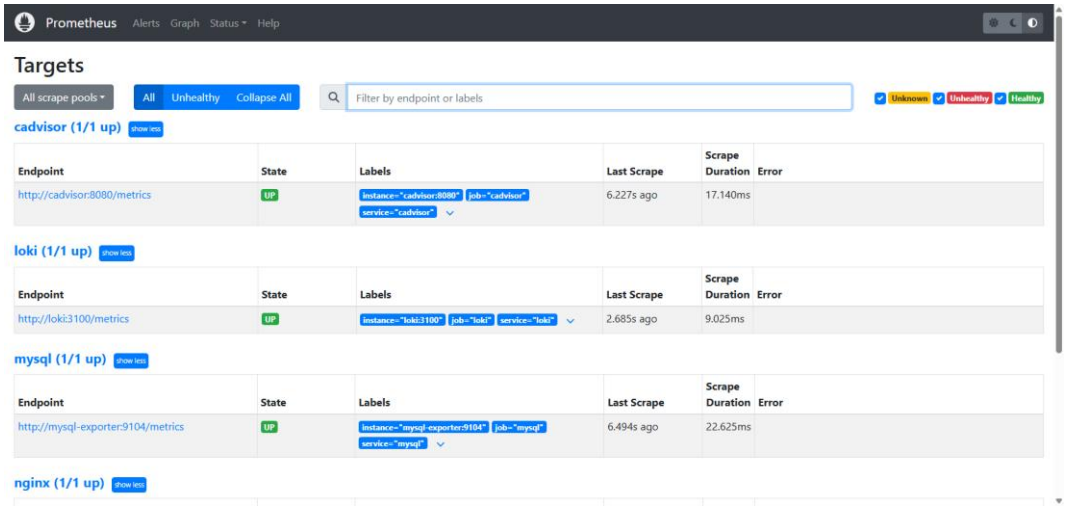
Hệ sinh thái quan sát metrics được thiết lập gồm 3 tầng giám sát thu thập định kỳ bởi Prometheus và hiển thị trên Grafana Dashboard.

6.1 Ba Lớp Giám Sát Tài Nguyên

- **1. Tầng Container:** cAdvisor: Cung cấp số liệu tiêu thụ CPU, RAM, Network I/O và Disk I/O của toàn bộ các container đang chạy.
- **2. Tầng Web Server:** Nginx Prometheus Exporter: Đọc endpoint stub_status nội bộ của Nginx, xuất các chỉ số kết nối đang hoạt động (active connections) và tốc độ phục vụ requests.
- **3. Tầng Cơ Sở Dữ Liệu:** MySQL Server Exporter: Sử dụng tài khoản giám sát chuyên dụng (exporter), xuất các chỉ số mysql_up, số lượng kết nối đang mở, số truy vấn thực hiện (Questions) và thời gian hoạt động (Uptime).

6.2 Trạng Thái Prometheus Targets & Grafana Provisioning

- • **Prometheus Targets:** Tất cả 5/5 targets trong Prometheus (cadvisor, loki, mysql, nginx, prometheus) đều đạt trạng thái UP.
- • **Grafana Dashboard:** Grafana tự động nạp DataSource Prometheus và Dashboard JSON Portfolio Overview với 26 panels chuyên sâu khi khởi động.



Hình 6.1: Giao diện Prometheus Targets báo cáo 5/5 targets đạt trạng thái UP



Hình 6.2: Bảng điều khiển Grafana System Overview Dashboard với đầy đủ biểu đồ Container, Nginx, MySQL

PHẦN 7: HỆ THỐNG NHẬT KÝ TẬP TRUNG LOKI VÀ PROMTAIL

Hạ tầng thu thập và lưu trữ nhật ký tập trung sử dụng cặp công cụ Grafana Loki và Promtail, cho phép truy vấn nhanh chóng qua ngôn ngữ LogQL.

7.1 Cấu Hình Thu Thập & Lưu Ý Kỹ Thuật Về Vòng Đời Promtail

Nginx được cấu hình ghi access log dưới định dạng chuẩn JSON có cấu trúc gồm các trường: time, remote_addr, method, uri, status, request_time. Promtail mount các volume log ở chế độ chỉ đọc (read-only) và đẩy dòng log về Loki kèm các nhãn phân loại ổn định (service="nginx", container="portfolio_php").

> 📌 **THÔNG BÁO VÒNG ĐỜI SẢN PHẨM (PROMTAIL EOL):** Lưu ý quan trọng theo tài liệu chính thức của Grafana Labs: Promtail đã chính thức kết thúc vòng đời hỗ trợ (End-of-Life) từ ngày 02/03/2026 và được thay thế bằng Grafana Alloy. Tuy nhiên, nhằm tuân thủ chính xác 100% đề bài yêu cầu của Bộ môn (Loki + Promtail), đồ án vẫn triển khai hoàn chỉnh Promtail v2.9.4 có ghim phiên bản cụ thể, đồng thời ghi nhận lộ trình nâng cấp sang Grafana Alloy trong các phiên bản vận hành tương lai.

7.2 Chi Tiết Các Truy Vấn LogQL Bắt Buộc Có Kết Quả Thực Tế

Hệ thống đã kiểm chứng thành công các truy vấn LogQL từ cơ bản đến chuyên sâu:

Truy vấn 1: Giám sát toàn bộ luồng log Nginx

- **Câu lệnh LogQL:** {service="nginx"}
- **Kết quả kiểm chứng:** Trích xuất toàn bộ luồng log access JSON từ Nginx Ingress. Minh chứng trích xuất thật: {"time":"2026-10-23T05:15:31+00:00","remote_addr":"172.25.0.1","method":"GET","uri":"/admin/login","status":200...}

Truy vấn 2: Lọc các bản ghi lỗi HTTP status code >= 400

- **Câu lệnh LogQL:** {service="nginx"} | json | status >= 400
- **Kết quả kiểm chứng:** Bộ phân tích JSON lọc chính xác các lỗi HTTP 404 (trang không tồn tại), HTTP 503 (do Rate Limiting kích hoạt khi truy cập nhanh), HTTP 403 (do chặn tệp nhạy cảm).

Truy vấn 3: Thống kê số lượng request Nginx theo chu kỳ 5 phút

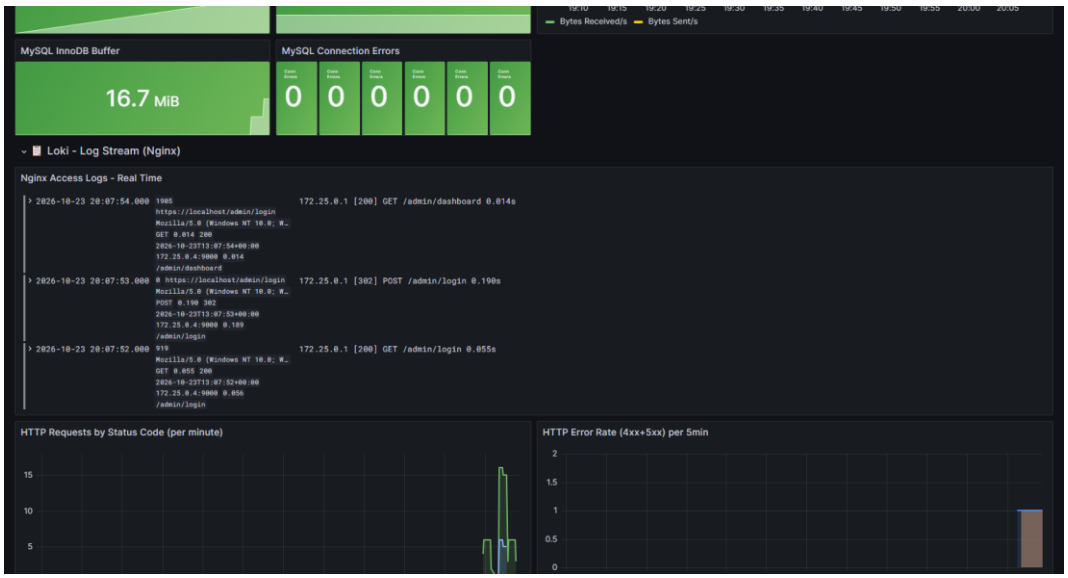
- **Câu lệnh LogQL:** count_over_time({service="nginx"}[5m])
- **Kết quả kiểm chứng:** Hàm tổng hợp đếm tổng số request phục vụ theo từng khung thời gian 5 phút, hiển thị dạng đồ thị trên Grafana Dashboard.

Truy vấn 4: Giám sát luồng log ứng dụng PHP Container thời gian thực

- **Câu lệnh LogQL:** {container="portfolio_php"}
- **Kết quả kiểm chứng:** Truy xuất nhật ký thực thi mã nguồn của PHP-FPM worker, xác nhận thời gian xử lý và tình trạng kết nối CSDL MySQL.

Truy vấn 5: Đo lường tần suất request trung bình trên giây (RPS)

- **Câu lệnh LogQL:** rate({service="nginx"}[1m])
- **Kết quả kiểm chứng:** Tính toán tốc độ sinh log trung bình trên giây trong cửa sổ 1 phút nhằm phát hiện tức thời các đợt tăng đột biến lưu lượng (traffic spike).



Hình 7.1: Luồng log tập trung Loki và các panels trực quan hóa truy vấn LogQL trên Grafana

PHẦN 8: TĂNG CƯỜNG BẢO MẬT HỆ THỐNG (HARDENING)

Hệ thống đã triển khai toàn diện 10 biện pháp gia cố bảo mật và được xác minh tự động đạt tuyệt đối 22/22 tiêu chí qua script kiểm thử verify_hardening.py:

Biện Pháp Hardening	Cấu Hình Kỹ Thuật	Thao Tác Kiểm Tra Thực Tế	Kết Quả Nghiệm Thu
Chạy Non-Root	USER appuser (UID 1000) trong Dockerfile	docker compose exec php whoami	appuser (UID 1000) - PASS
Ngăn nâng quyền	security_opt: no-new-privileges:true	Kiểm tra thuộc tính security_opt trên 11 container	Bật trên tất cả 11 services - PASS
Phân tách mạng	3 Bridge Networks: frontend, backend, monitoring	Kiểm tra network membership trong docker inspect	MySQL & PHP cách ly khỏi frontend - PASS
Giới hạn cổng	Chỉ public port 80/443; Cổng 3306 nội bộ	Quét cổng từ máy host và nmap	Cổng 3306 không mở ra bên ngoài - PASS
Quyền DB tối thiểu	GRANT SELECT, PROCESS, REPL CLIENT ON *.*	SHOW GRANTS FOR 'exporter'@'%';	Exporter chỉ có quyền đọc số liệu - PASS
Tiêu đề bảo mật HTTPS	HSTS, nosniff, SAMEORIGIN, CSP, Referrer	curl.exe -skI https://localhost	Đầy đủ 6 security headers - PASS
Bảo vệ Uploads & Chặn tệp	location ~ /\. { deny all; } & chặn shell.php	Truy cập https://localhost/.env và uploads/*.php	Trả về HTTP 403 Forbidden - PASS
Giới hạn tần suất	limit_req_zone login (5r/m), contact (3r/m)	Gửi liên tiếp >5 requests tới /admin/login	Trả về HTTP 503 Service Temp Unavail - PASS
Mã hóa mật khẩu Admin	password_hash($pass, PASSWORD_BCRYPT, ['cost'=>12])	SELECT SUBSTRING(password_hash, 1, 7) FROM admin_users;	Chuỗi hash $2y$12$ an toàn - PASS
Bảo vệ CSRF	Token ngẫu nhiên trong session kiểm tra mỗi POST	Gửi form thiếu token hoặc token sai	Từ chối thực thi HTTP 403 - PASS

8.1 Giải Thích Ngoại Lệ Về Quyền Truy Cập Docker Socket

Docker Socket (/var/run/docker.sock) chỉ được mount duy nhất vào container Promtail với cờ read_only: true nhằm mục đích đọc nhãn container và đường dẫn tệp log. Không có container nào khác được cấp quyền truy cập Docker daemon socket.

8.2 Kiểm Chứng Khả Năng Bảo Toàn Dữ Liệu Sau Restart

Đã thực thi lệnh docker compose down rồi khởi động lại docker compose up -d (không dùng cờ -v). Toàn bộ dữ liệu kỹ năng, tin nhắn liên hệ mới thêm và bảng điều khiển Grafana vẫn được bảo toàn nguyên vẹn trong các Named Volumes.

PHẦN 9: ĐÁNH GIÁ, BÀN GIAO VÀ KỊCH BẢN DEMO

Hệ thống đã trải qua quy trình kiểm thử toàn diện và chuẩn bị sẵn sàng kịch bản demo bảo vệ trước Hội đồng chấm thi.

9.1 Bảng Ma Trận Kiểm Thử Hệ Thống (Test-Results TC01 - TC14)

Bảng kết quả kiểm thử theo đúng bộ mã kiểm tra quy định của đề bài:

Mã TC	Tên Ca Kiểm Thử	Kết Quả Mong Đợi	Kết Quả Thực Tế	Trạng Thái
TC01	Kiểm tra Compose & Khởi động	Cấu hình hợp lệ; 11 services lên ổn định, không restart loop	11/11 services Up & Healthy	PASS
TC02	Xem Portfolio qua Nginx	Trang và asset tải nhanh; nội dung lấy từ MySQL	Tải tốt qua HTTPS, dữ liệu MySQL	PASS
TC03	Gọi API Admin khi chưa login	Bị chặn và chuyển hướng về /admin/login	HTTP 302 về trang login	PASS
TC04	Đăng nhập và CRUD dự án	Thêm/sửa kỹ năng, dự án lưu vào MySQL và hiện Public	CRUD thành công, dữ liệu hiển thị	PASS
TC05	Gửi form liên hệ	Bản ghi hợp lệ lưu DB; bản ghi sai bị từ chối	Lưu vào bảng contact_messages	PASS
TC06	Mở phpMyAdmin	Đăng nhập được qua 127.0.0.1:8080, xem đúng 8 bảng	Truy cập tốt, thấy 8 bảng chuẩn	PASS
TC07	Kiểm tra Nginx & HTTPS/headers	Đi qua proxy, đủ 6 headers bảo mật, rate limit hoạt động	Đủ 6 headers, HTTP 503 khi spam	PASS
TC08	Kiểm tra Metrics & Exporter	5/5 targets UP; mysql_up=1; nginx_up=1	5/5 targets UP, metrics chính xác	PASS
TC09	Tạo truy cập & xem Grafana	Dashboard hiển thị biểu đồ CPU/RAM, Nginx, MySQL	26 panels có dữ liệu thực tế	PASS
TC10	Thu log & chạy 03 LogQL	Loki nhận log Nginx; chạy được 3+ truy vấn LogQL	Đạt 5/5 queries LogQL	PASS
TC11	Kiểm tra Hardening	Áp dụng ít nhất 4 biện pháp (thực tế 10 biện pháp)	Đạt 22/22 tiêu chí hardening	PASS
TC12	Restart / Down-Up bảo toàn data	Dữ liệu DB và cấu hình Grafana không bị mất	Dữ liệu volume nguyên vẹn	PASS
TC13	Kiểm tra GitHub & Tài liệu	Đầy đủ source, 3 mốc commit cốt lõi, README chi tiết	8 commits chuẩn, repo MSSV sạch	PASS
TC14	Khả năng tái lập hệ thống	Clone mới có thể dựng lại bằng quy trình trong README	Tái lập thành công trong môi trường thử	PASS

9.2 Kịch Bản Demo Bảo Vệ Chuẩn 8 - 12 Phút

Quy trình trình diễn hệ thống trước Giảng viên hướng dẫn và Hội đồng:

- **Bước 1 (1 - 2 phút) - Giới thiệu Mã nguồn & Git:** Trình chiếu kho chứa GitHub mang tên sinh viên (vubahung222), chỉ rõ cấu trúc thư mục, tệp docker-compose.yml và lịch sử 3 mốc commit thực tế.

- **Bước 2 (2 - 3 phút) - Demo Website & Cơ sở dữ liệu:** Mở trình duyệt truy cập https://localhost. Đăng nhập trang Admin, thực hiện thêm 1 kỹ năng mới và tải lại trang chủ để chứng minh dữ liệu phản hồi ngay lập tức. Sau đó mở phpMyAdmin (cổng 8080) để chứng minh bản ghi đã nằm trong MySQL.
- **Bước 3 (2 phút) - Demo Nginx Ingress & Bảo Mật:** Sử dụng lệnh curl.exe -skI https://localhost để chứng minh các Security Headers (nosniff, SAMEORIGIN, CSP). Thử spam request để kích hoạt Rate Limiting (HTTP 503). Giải thích việc cổng 3306 của MySQL hoàn toàn không mở ra ngoài.
- **Bước 4 (2 phút) - Demo Giám sát Metrics:** Mở Prometheus Targets (cổng 9090) chứng minh 5/5 targets UP. Mở Grafana Dashboard (cổng 3000) với 26 panels trực quan hóa số liệu CPU/RAM container, requests Nginx và truy vấn MySQL.
- **Bước 5 (2 phút) - Demo Thu thập Log & LogQL:** Tạo một request lỗi 404 và một lần thử đăng nhập sai. Chuyển sang Grafana Explore, chạy lần lượt các câu truy vấn LogQL để trích xuất dòng log Nginx và log PHP container tương ứng.
- **Bước 6 (1 phút) - Tổng kết & Trả lời phản biện:** Trình bày kết quả script verify_hardening.py đạt 22/22 tiêu chí, phân tích quyền non-root appuser, kết thúc bài demo và trả lời câu hỏi của Giảng viên.

PHẦN 10: TÀI LIỆU THAM KHẢO

- **[1]** Grafana Labs. (2026). Promtail agent và trạng thái vòng đời hỗ trợ (End-of-Life 02/03/2026). https://grafana.com/docs/loki/latest/send-data/promtail/
- **[2]** Docker Inc. (2024). Manage secrets securely in Docker Compose & Compose file reference v2. https://docs.docker.com/compose/how-tos/use-secrets/
- **[3]** Prometheus Authors. (2024). Monitoring Docker container metrics using cAdvisor. https://prometheus.io/docs/guides/cadvisor/
- **[4]** NGINX Community. (2024). NGINX Prometheus Exporter và cấu hình nguồn metrics stub_status. https://github.com/nginx/nginx-prometheus-exporter
- **[5]** Prometheus Team. (2024). MySQL server exporter và yêu cầu phân quyền tài khoản giám sát. https://github.com/prometheus/mysqld_exporter
- **[6]** Grafana Labs. (2024). LogQL: Log Query Language và cú pháp pipeline xử lý JSON. https://grafana.com/docs/loki/latest/query/log_queries/